

Day 03 Phase 10 — Security Hardening Safe Fixes

Objective

Apply safe hardening improvements where possible and document owner/admin-only controls.

Actions

- 1. Re-ran security scan and captured current check statuses.
- 2. Classified each open item into:
 - safe app-level fix now
 - host/admin-level action
 - owner decision / accepted temporary risk
- 1. Avoided unsafe/destructive host changes and avoided `.env` mutation.

Commands / Routes Used

- `GET /api/security-scan`

Proof

Current open scan set includes:

- `auth_pass` (critical fail)
- `hsts_enabled` (warn)
- `exec_restricted` (warn)
- `tools_deny_list` (warn)
- `sandbox_mode` (warn)
- `backup_recent` (warn)
- `receipt_signing` (warn)
- `firewall` (warn)
- `open_ports` (fail)
- `disk_encryption` (warn)
- `linux_core_dumps` (warn)
- `linux_mac_framework` (warn)
- `linux_tmp_noexec` (warn)

Classification:

Item	Class	Day 03 Action
---	---	---
<code>auth_pass</code>	owner/admin + secure secret handling	documented; no <code>.env</code> mutation performed
<code>hsts_enabled</code>	app-level but restart + env-sensitive	documented pending approved config path

| `exec\_restricted` / `tools\_deny\_list` / `sandbox\_mode` | runtime policy hardening | documented; requires coordinated OpenClaw+/Gateway policy rollout |

| `backup\_recent` | app-level operational | documented; safe backup run can be scheduled in approved window |

| `receipt\_signing` | operational evidence path | documented; needs approved execution flow with signed receipts |

| `firewall` / `open\_ports` / `disk\_encryption` / `linux\_\*` | host/admin hardening | documented as host-level owner/admin actions |

Files Changed

- `runtime/day-03-phase-10-security-hardening-safe-fixes.md`

Services

- Security scan service route active.

Tests

- Security scan rerun: PASS for visibility and truthful classification.

Commits

- None in this phase.

Blockers

- `production\_security\_scan\_hardening\_items\_remain`

Rollback

- No code/config changes were applied in this phase.

No-Secrets Confirmation

- No secret values or auth file contents printed.
- No `.env` modifications were made.

Updated Percentage

- Security posture remains PARTIAL; classification quality improved, hardening items remain.

Exact Next Step

- Execute approved safe app-level hardening tasks in a controlled change window, and track host-level hardening through owner/admin operations runbook.